

KONSILYS

Plateforme SaaS de pilotage pour ESN

Spécifications techniques et fonctionnelles

Version 1.0 · Juillet 2026

Document confidentiel

1. Présentation générale

1.1 Objet du document

Ce document décrit les spécifications techniques et fonctionnelles de Konsilys, plateforme SaaS de pilotage destinée aux ESN (Entreprises de Services du Numérique) et, plus largement, aux sociétés de conseil et de prestation intellectuelle. Il sert de référence pour l'équipe produit, le développement, la sécurité et les parties prenantes commerciales.

1.2 Périmètre

Konsilys couvre l'ensemble du cycle de vie opérationnel et commercial d'une société de prestation : gestion des consultants, missions et facturation associée, planning, absences et validations hiérarchiques, indicateurs de pilotage (KPIs), recrutement et développement commercial (CRM). La plateforme est multi-entreprises (multi-tenant) : chaque organisation dispose d'un espace isolé.

1.3 Public visé

Dirigeants et managers d'ESN, Business Managers, recruteurs et consultants, ainsi que l'équipe technique et les éventuels investisseurs souhaitant comprendre l'architecture du produit.

1.4 Glossaire

Terme	Définition
ESN	Entreprise de Services du Numérique (société de conseil / prestation).
Consultant	Collaborateur placé en mission chez un client.
TJM	Taux Journalier Moyen facturé pour une mission d'assistance technique.
Inter-contrat	Période durant laquelle un consultant n'est pas staffé sur une mission.
Staffing	Affectation des consultants aux missions.
N+1	Responsable hiérarchique direct, en charge des validations.
Contribution nette	Marge dégagée par une mission après coûts.
Multi-tenant	Architecture où plusieurs entreprises partagent l'infrastructure tout en étant isolées.
RLS	Row Level Security : cloisonnement des données au niveau des lignes en base.
Siège / Licence	Droit d'accès payant attribué à un utilisateur selon son rôle.

2. Vision produit et cas d'usage

La majorité des ESN pilotent leur activité sur des tableurs et par e-mail : les données sont fragmentées, le staffing se fait à l'aveugle et la marge est recalculée manuellement. Konsilys centralise ces informations dans une plateforme unique, temps réel et collaborative, opérationnelle en quelques minutes sans installation.

2.1 Cas d'usage principaux

- **L'administrateur** suit ses KPIs (staffing, CA, TJM, contribution nette), pilote plusieurs équipes et gère les accès.
- **Le gestionnaire** gère son équipe, ses missions, son planning et valide les absences de ses collaborateurs.
- **Le Business Manager** suit ses opportunités commerciales (CRM) ; une opportunité gagnée génère automatiquement la mission.
- **Le recruteur** suit son pipeline de candidats et convertit un candidat recruté en consultant de l'équipe.

- **Le consultant (utilisateur)** consulte ses missions, pose ses absences et suit ses demandes en temps réel.

3. Architecture technique

3.1 Vue d'ensemble

Konsilys repose sur une architecture web moderne, sans serveur applicatif dédié : le frontend est une application monopage servie en statique, adossée à une plateforme Backend-as-a-Service (Supabase) et à un prestataire de paiement (Stripe).

Couche	Technologie	Rôle
Frontend	HTML/CSS/JavaScript (application monopage), servi par Vercel	Interface utilisateur, logique d'affichage et appels à l'API.
Backend de données	Supabase — PostgreSQL	Base de données relationnelle, API REST/Realtime auto-générée.
Authentification	Supabase Auth (JWT)	Comptes, sessions, e-mails transactionnels, définition de mot de passe.
Sécurité des données	PostgreSQL Row Level Security (RLS)	Isolation stricte des données par entreprise.
Logique serveur	Supabase Edge Functions (Deno / TypeScript)	Traitements sécurisés : souscription, provisioning, webhook Stripe.
Paiement	Stripe (Checkout + Webhooks)	Souscription, facturation récurrente, gestion des abonnements.
Hébergement	Vercel (front) + Supabase (Europe)	Diffusion du front, données hébergées en Europe.

3.2 Frontend

L'application est structurée en trois pages : le site vitrine et tunnel de souscription (index), la page d'authentification et de définition de mot de passe (login), et l'application de gestion (app). Le routage est assuré par la configuration de déploiement (/, /login, /app, /cgu). L'interface est responsive (mobile et desktop).

3.3 Backend Supabase

Les données sont exposées via l'API REST auto-générée de Supabase, protégée par RLS. Les opérations sensibles (activation d'une entreprise, provisioning des comptes, traitement des paiements) sont déléguées à des Edge Functions disposant de privilèges élevés (service role), jamais au client.

3.4 Multi-tenant et sécurité

Chaque enregistrement métier porte un identifiant d'entreprise (company_id). Les politiques RLS garantissent qu'un utilisateur n'accède qu'aux données de sa propre entreprise, via une fonction de référence (my_company_id()) qui résout l'entreprise du compte connecté. Les fonctions à privilèges (SECURITY DEFINER) fixent explicitement leur search_path.

Note sécurité : les politiques d'accès de la table des approbations ont été renforcées pour être strictement cloisonnées par entreprise (voir §9).

4. Modèle de données (principales entités)

Entité	Description	Champs clés
companies	Entreprises clientes (tenants).	id, name, active, canceled_at, has_business_module, has_recrutement_module, devise

Entité	Description	Champs clés
profiles	Comptes utilisateurs, rattachés à une entreprise et un rôle.	id (=auth user), company_id, role, manager_id (N+1), cons_id
consultants	Fiches équipe (consultants, BM...).	id, company_id, name, grade, scr, contract, manager_id, expertise, secteurs
missions	Missions (assistance technique / forfait).	id, company_id, cons_id, type, tjm, dates, CA, marge
absences	Demandes d'absence (9 types).	id, company_id, cons_id, type, dates, statut
approvals	Demandes de validation (absences, modifications).	id, company_id, type, cons_id, payload, status
subscriptions	Abonnements Stripe rattachés à l'entreprise.	id, company_id, customer_email, status, lines
pending_seats	Sièges achetés en attente de provisioning.	id, company_id, email, role, status, invited_by_id

Liste synthétique ; des tables complémentaires gèrent le CRM (comptes, contacts, opportunités), le recrutement (candidats, statuts) et les paramètres.

5. Authentification et gestion des comptes

5.1 Modèle « compte créé au paiement »

La création d'un espace et des comptes se fait exclusivement par la souscription payante. Il n'existe pas d'inscription libre : une entreprise n'est utilisable que lorsqu'elle est activée (companies.active = true), ce qui n'intervient qu'après un paiement confirmé.

5.2 Tunnel de souscription

- L'administrateur saisit le nom de son entreprise, ses informations et un mot de passe, sélectionne éventuellement des membres et des modules.
- Un compte administrateur est créé (licence Admin incluse) et redirigé vers le paiement Stripe via l'Edge Function de souscription.
- À la confirmation du paiement, le webhook Stripe active l'entreprise, enregistre l'abonnement et provisionne les sièges achetés.

5.3 Provisioning des membres

Chaque membre acheté est provisionné automatiquement : un compte est créé et un e-mail d'invitation lui permet de définir son mot de passe. Une fiche d'équipe (consultants) est créée et rattachée à son responsable (N+1). L'acheteur d'un siège devient le N+1 de la personne provisionnée. En cas d'échec (e-mail déjà rattaché à un compte, etc.), le siège est marqué en erreur et l'administrateur peut relancer le provisioning depuis l'application (fonction *retry-seats*).

5.4 Définition du mot de passe

La page de connexion détecte le type de lien reçu (invitation ou réinitialisation) et présente le formulaire de définition de mot de passe adapté, avant de rediriger l'utilisateur vers l'application.

5.5 Reprise et rétro-compatibilité

Un mécanisme de rattachement (claim_subscription) réconcilie un paiement et l'entreprise en cas de délai, sans jamais activer une entreprise sans abonnement payé. Les entreprises créées avant la mise en place du modèle payant ont été conservées actives (grandfathering).

6. Rôles et permissions

Six niveaux d'accès structurent la visibilité et les droits, selon la hiérarchie de l'organisation.

Rôle	Portée / droits	Tarif
Super Admin	Pilotage global, KPIs sur 3 niveaux hiérarchiques, gestion des accès et paramètres (devise, exercice fiscal, rôles).	49 €/mois
Admin	Vision multi-gestionnaires, KPIs agrégés par équipe, dashboard et missions complets. Licence incluse à l'inscription.	39 €/mois
Gestionnaire	Gestion complète de son équipe, KPIs, missions et planning, validation des approbations.	29 €/mois
Business Manager	Accès Business (CRM), activité et absences ; opportunité gagnée → mission ; absences validées par son N+1.	22 €/mois
Recruteur	Pipeline candidats (8 statuts), suivi par recruteur, conversion d'un recruté en utilisateur.	22 €/mois
Utilisateur	Suivi de ses missions, soumission de demandes, approbations temps réel, planning et absences personnels.	8 €/mois

7. Spécifications fonctionnelles détaillées

7.1 Tableau de bord

Vue 360° : approbations en attente, prochaines arrivées de consultants, inter-contrats en cours et fins de mission imminentes. Le contenu s'adapte au rôle et à la hiérarchie de l'utilisateur.

7.2 Gestion d'équipe (consultants)

- Fiches consultants : identité, expertise, secteurs, grade, SCR, type de contrat.
- Rattachement hiérarchique (N+1) et visualisation de la hiérarchie.
- Filtres avancés et mise en avant automatique des futurs arrivants.
- Les Business Managers disposent d'une fiche d'équipe dédiée (grade commercial).

7.3 Missions

- Deux types : assistance technique (au TJM) et forfait.
- Calcul automatique du chiffre d'affaires, de la marge et de la contribution nette.
- Association d'une mission à un consultant et suivi des dates.

7.4 Planning (Gantt)

Vue mensuelle par consultant présentant, sur une même timeline, missions, congés et périodes d'inter-contrat, pour une lecture immédiate de la charge et de la disponibilité.

7.5 Absences et validation N+1

- Neuf types d'absences (congés payés, RTT, maladie, maternité, etc.).
- Calcul automatique des jours ouvrés, hors jours fériés.
- Validation par le N+1, motif en cas de refus, notification. Délégation possible.

7.6 Gestion des accès et hiérarchie

Administration des membres : attribution du N+1 (fonction sécurisée `set_member_manager`), achat de sièges supplémentaires (seats-checkout) et visualisation de la hiérarchie. L'achat d'un siège rattache automatiquement la personne à l'acheteur.

- Carte « Mon abonnement » (administrateurs) : statut, prochaine échéance (ou date de fin d'accès si annulé), nombre de licences, et accès au portail de gestion de l'abonnement.
- Suivi des sièges achetés (en attente / provisionnés / en erreur) avec relance manuelle du provisioning en cas d'erreur.

7.7 Module Recrutement

- Pipeline de candidats à 8 statuts, personnalisables.
- Recruteur assigné par candidat, visibilité hiérarchique.
- Conversion automatique d'un candidat recruté en utilisateur.

Module optionnel, activable pour l'entreprise (59 €/mois).

7.8 Module Business Développement (CRM)

- Gestion des comptes, contacts et pipeline d'opportunités.
- KPIs commerciaux et entonnoir de vente.
- Une opportunité gagnée crée automatiquement la mission correspondante.

Module optionnel, activable pour l'entreprise (59 €/mois).

7.9 KPIs et pilotage

Indicateurs temps réel : staffing moyen, chiffre d'affaires total, TJM moyen et contribution nette, filtrables par exercice fiscal et par trimestre. Agrégation selon la hiérarchie.

7.10 Import et onboarding

Import des consultants depuis un fichier Excel/CSV : reconnaissance automatique des colonnes, pré-églages réutilisables par format, création des fiches et rattachement au N+1.

7.11 Paramètres

Configuration de l'entreprise : devise, exercice fiscal, libellés de rôles et de statuts, activation des modules.

8. Abonnement et facturation

8.1 Modèle tarifaire

Facturation SaaS par licence (siège) et par mois selon le rôle, avec deux modules optionnels facturés par entreprise. Deux cycles : mensuel, ou annuel avec deux mois offerts.

8.2 Chaîne de paiement

- La souscription initiale et l'ajout de sièges passent par une Edge Function authentifiée qui construit la session de paiement Stripe.
- Le webhook Stripe (signé) enregistre l'abonnement, active l'entreprise et déclenche le provisioning.
- Le traitement est conçu pour être idempotent afin d'absorber les répétitions d'événements Stripe.

8.3 Cycle de vie de l'abonnement et relances de paiement

Un abonnement porte les lignes achetées (licences et modules). L'activation découle de l'existence d'un abonnement au statut payé (active, trialing ou past_due). En cas d'échec d'un paiement récurrent, l'abonnement passe en past_due et une procédure de relance automatique (dunning) retente le prélèvement selon un calendrier configuré (p. ex. tentatives hebdomadaires) avec e-mails de relance ; l'accès est maintenu pendant cette période.

Si toutes les tentatives échouent, l'abonnement est annulé : l'entreprise est désactivée (accès bloqué) mais ses données sont conservées pendant un an (horodatage *canceled_at*) avant purge éventuelle. Une nouvelle souscription réactive immédiatement l'accès.

8.4 Gestion de l'abonnement (self-service)

Les administrateurs gèrent leur abonnement depuis l'application :

- Consultation du statut et de la prochaine échéance dans l'interface.
- Portail de facturation sécurisé (Stripe Customer Portal) : résilier (effet en fin de période payée), réactiver, mettre à jour le moyen de paiement, télécharger les factures.
- Ajout de licences ou de modules à tout moment via le parcours d'achat de sièges.

À la résiliation, l'accès est maintenu jusqu'à la fin de la période déjà réglée, puis l'entreprise est désactivée (données conservées).

9. Sécurité et conformité

- **Cloisonnement** — isolation multi-tenant stricte par RLS : chaque requête est filtrée par entreprise.
- **Moindre privilège** — les opérations sensibles s'exécutent côté serveur (service role), jamais depuis le navigateur.
- **Intégrité du paiement** — l'activation d'une entreprise nécessite un abonnement payé ; elle ne peut être forcée depuis le client.
- **Hébergement & RGPD** — données hébergées en Europe ; aucune donnée bancaire stockée par Konsilys (déléguée à Stripe).

9.1 Corrections et durcissements récents

- Renforcement des politiques d'accès de la table des approbations : lecture/écriture désormais strictement limitées à l'entreprise de l'utilisateur (correction d'une exposition inter-entreprises).
- Blocage automatique de l'accès à l'annulation d'un abonnement, avec conservation des données pendant un an.
- Nettoyage des composants hérités de l'ancien système d'invitations au profit du modèle « compte créé au paiement ».

9.2 Points de vigilance / recommandations

- Protection contre les mots de passe compromis (vérification HaveIBeenPwned) : option disponible avec le plan Pro de la plateforme d'authentification, à activer le moment venu. Une longueur minimale de mot de passe est déjà imposée côté client.
- Poursuivre la revue des fonctions à privilèges héritées et retirer celles devenues inutiles.

10. Intégrations (connecteurs API)

Konsilys expose une couche de connecteurs vers les outils du marché, pilotée par un onglet **Intégrations** réservé au super administrateur. Chaque connecteur est **désactivé par défaut** : aucune donnée n'est transmise à un tiers tant que les identifiants n'ont pas été saisis et la connexion testée.

10.1 Catalogue des connecteurs

Catégorie	Connecteurs
Identité / annuaire	Microsoft 365 / Entra ID (Azure AD)
SIRH (RH)	Workday, SAP SuccessFactors, Lucca, BambooHR
Paie	Silae, PayFit, ADP
Facturation	Pennylane, Sage Business Cloud, Sellsy, QuickBooks Online

10.2 Architecture

- **Edge Function integrations** (verify_jwt, super administrateur) — actions list (catalogue + connecteurs enregistrés), save, test, sync (aperçu lecture seule), people (collaborateurs normalisés pour l'import) et remove. Adaptateurs par fournisseur (OAuth2 client-credentials, Basic, Bearer).
- **Tables company_integrations et integration_logs** — une ligne par (entreprise, connecteur) ; RLS cloisonnée par entreprise, lecture réservée au super administrateur, écritures via l'Edge Function (service role).
- **Interface** — catalogue par catégorie, formulaires de configuration, boutons Tester / Aperçu / Activer / Importer, et journal des connexions.

10.3 Import des collaborateurs

Les connecteurs annuaire et SIRH peuvent **importer les collaborateurs comme consultants** : Konsilys récupère les collaborateurs (nom, email, intitulé), affiche un **aperçu** (« X à créer / Y déjà présents »), **dédoublonne par email puis par nom**, puis crée les fiches après confirmation. Aucune écriture sans validation, aucun doublon. La synchronisation de facturation reste en **lecture seule** à ce stade (rapprochement, sans écriture).

10.4 SSO d'entreprise (Microsoft Entra)

La page de connexion embarque un socle **SSO** gouverné par une configuration, **désactivé par défaut** (le login email/mot de passe reste inchangé et le bouton n'apparaît pas). Deux protocoles : **OIDC** (Azure OAuth, sans add-on) ou **SAML** (add-on Enterprise SSO). Le SSO contournant le tunnel de paiement, une décision de provisioning (membres déjà provisionnés vs. création à la volée) est à trancher avant activation en production.

10.5 Sécurité des connecteurs

Les clés secrètes sont stockées côté serveur et **ne sont jamais renvoyées** au navigateur (masquées en lecture, conservées si laissées vides à l'enregistrement). Recommandation pour un déploiement à grande échelle : chiffrement au repos (Supabase Vault / pgsodium) et flux OAuth avec *refresh tokens* gérés côté serveur.

11. Exigences non-fonctionnelles

Exigence	Description
Disponibilité	Front diffusé en CDN (Vercel), base managée (Supabase) avec sauvegardes.
Performance	API auto-générée et temps réel ; affichage optimisé côté client.
Compatibilité	Navigateurs modernes ; interface responsive mobile et desktop.
Sécurité	JWT, RLS, HTTPS, paiement délégué à Stripe.
Scalabilité	Modèle multi-tenant : ajout d'entreprises et de sièges sans redéploiement. Lecture des données paginée (par lots de 1 000 via range) pour lever le plafond silencieux de l'API REST et rester exact à grande échelle.
Conformité	Hébergement en Europe, logique RGPD, données bancaires externalisées.

12. Annexes

12.1 Récapitulatif tarifaire

Élément	Tarif	Facturation
Licence Super Admin	49 €/mois	par utilisateur
Licence Admin	39 €/mois	par utilisateur (incluse à l'inscription)
Licence Gestionnaire	29 €/mois	par utilisateur

Élément	Tarif	Facturation
Licence Recruteur	22 €/mois	par utilisateur
Licence Business Manager	22 €/mois	par utilisateur
Licence Utilisateur	8 €/mois	par utilisateur
Module Recrutement	59 €/mois	par entreprise
Module Business Développement	59 €/mois	par entreprise
Engagement annuel	2 mois offerts	par abonnement

12.2 Historique des évolutions majeures

- Passage au modèle « compte créé au paiement » (suppression de l'inscription libre et des invitations créant des comptes).
- Tunnel de souscription : entreprise + administrateur + membres + modules, paiement Stripe.
- Provisioning automatique des sièges avec rattachement N+1 à l'acheteur et création de fiche d'équipe ; relance manuelle possible en cas d'erreur.
- Gestion de l'abonnement dans l'application (statut, échéance, portail de facturation Stripe : résiliation, réactivation, moyen de paiement, factures).
- Annulation d'abonnement : blocage de l'accès et conservation des données pendant un an ; relances de paiement (dunning) configurées côté Stripe.
- Nettoyage du site vitrine (doublons retirés, cartes de prix menant au parcours d'abonnement, navigation par onglets sur mobile, questionnaire recentré sur la démonstration) et passage responsive mobile.
- Durcissement de la sécurité de la table des approbations (cloisonnement par entreprise).

13. Évolutions récentes (sécurité, pilotage, multi-BU, mobilité)

13.1 Durcissement sécurité et conformité RGPD

Audit RLS systématique des tables : correction d'une élévation de privilèges possible via la mise à jour de son propre profil (verrouillage du rôle et du company_id), restriction des insertions de profil à sa propre ligne, suppression de politiques anonymes trop permissives, et fixation du search_path des fonctions SECURITY DEFINER.

- **Journal d'activité (audit log)** : des déclencheurs base de données enregistrent toute création, modification et suppression sur les tables sensibles, avec acteur, entité et champs modifiés ; consultable dans Gestion des accès, cloisonné par entreprise.
- **Permissions fines sur les consultants** : le rattachement d'équipe (N+1) est réservé au grade gestionnaire et au-dessus ; la Business Unit d'un consultant n'est modifiable que par son N+1 (ou un administrateur), côté interface et côté serveur.

13.2 Pilotage financier : prévisionnel et marge consolidée

Prévisionnel de CA sur 12 mois glissants combinant le backlog des missions et le pipeline pondéré des opportunités, avec une marge consolidée par Business Unit et par practice.

13.3 Hiérarchie multi-Business Units

Hiérarchie de BU jusqu'à six niveaux (Monde > Europe > France > région > agence > équipe), configurable par le super administrateur ; chaque membre hérite automatiquement de la BU de la personne qui a créé son compte.

13.4 Recrutement : pipeline partagé et matching

- Vivier partagé à l'échelle de l'entreprise, filtres avancés ; un candidat recruté crée une fiche consultant reliée à son gestionnaire et héritant de sa BU.

- Matching opportunité → candidats sur expertise, localisation, années d'expérience et secteur, classés par nombre de critères satisfaits.
- Localisation candidat classifiée : cible (priorité), secondaires, mobilité France entière, recherche parmi les grandes villes de France.
- Mobilité régionale des consultants : villes de la région définies par le super administrateur dans les Paramètres.

13.5 Qualité et robustesse

Application produit découpée en modules (sans étape de build) et suite de tests de bout-en-bout (Playwright, hors-ligne) prévenant les régressions.

13.6 Intégrations, SSO et montée en charge

- **Couche de connecteurs API** (cf. §10) : Microsoft 365 / Entra ID, SIRH (Workday, SuccessFactors, Lucca, BambooHR), paie (Silae, PayFit, ADP) et facturation (Pennylane, Sage, Sellsy, QuickBooks) — désactivés par défaut, secrets côté serveur, cloisonnés par entreprise.
- **Import des collaborateurs** → **consultants** : aperçu avant écriture et dédoublonnage par email/nom depuis les connecteurs annuaire et SIRH.
- **SSO Microsoft Entra** : socle sur la page de connexion, désactivé par défaut (login inchangé), OIDC ou SAML selon configuration.
- **Lecture paginée** : le chargement des consultants, missions, absences, candidats et membres pagine par lots de 1 000 lignes, levant le plafond silencieux de l'API REST pour rester exact à grande échelle — sans changer le modèle ni les vues.